

Written Information Security Program (WISP)

Master security policy — NIST CSF 2.0 program charter

Document ID: BVT-POL-031

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Program Governance (GV)

- Security roles: the Managing Partner acts as security officer; every user is responsible for policy compliance; managed-service engineers enforce technical controls.
- Risk management: a risk register is maintained and reviewed quarterly; risks are ranked by likelihood × impact and assigned owners and treatment plans (mitigate, transfer, accept, avoid).
- Policy suite: this WISP is implemented through the topical policies BVT-POL-032 through BVT-POL-044, incorporated by reference.
- Supply chain: vendors handling company or client data are assessed under the Vendor Risk Management Policy (BVT-POL-041).

Framework Mapping Overview

CSF 2.0 Function	Primary Implementing Policies / Practices
GOVERN (GV)	This WISP; risk register; vendor risk policy; awareness policy
IDENTIFY (ID)	Asset inventory (RMM); data classification; environment questionnaires; vulnerability management
PROTECT (PR)	Access control; password/MFA; encryption; patching; remote access; BYOD; physical security
DETECT (DE)	Audit logging & monitoring; EDR; email security; alert triage procedures
RESPOND (RS)	Incident Response Plan and playbooks (BVT-IRP series); breach notification procedure
RECOVER (RC)	Backup policy; disaster recovery and business continuity plans

Data Protection Principles

- Least privilege and need-to-know for all access.
- Defense in depth: no single control is relied upon to prevent compromise.
- Secure by default: new systems are hardened before production use.
- Verify, then trust: identity verification is required for sensitive requests, including internal ones.
- Client data is handled per contract, the DPA, and applicable law; it is never used for unrelated purposes.

Compliance and Review

The security officer reviews this program annually and after any significant incident, environment change, or regulatory development, updating policies and the risk register accordingly. Evidence of reviews, training completion, access reviews, restore tests, and exercises is retained for at least three (3) years.